

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
I	Preliminary remarks	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
II	Requirements	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
1	IT strategy	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
1.1	IT strategy	The IT strategy shall fulfil the requirements set out in AT 4.2 of MaRisk. This includes in particular the requirement for the management board to define a sustainable IT strategy outlining the institution's objectives and the measures to be taken to achieve these objectives.	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	5	
1.1	IT strategy	The IT strategy shall fulfil the requirements set out in AT 4.2 of MaRisk. This includes in particular the requirement for the management board to define a sustainable IT strategy outlining the institution's objectives and the measures to be taken to achieve these objectives.	Functional	Intersects With	Strategic Plan & Objectives	PRM-01.1	Mechanisms exist to establish a: (1) Strategic security, compliance and resilience-specific business plan; and (2) Set of objectives to achieve that plan.	5	
1.2	IT strategy	The management board shall define an IT strategy that is consistent with the business strategy. As a minimum it shall contain:	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	5	
1.2	IT strategy	The management board shall define an IT strategy that is consistent with the business strategy. As a minimum it shall contain:	Functional	Intersects With	Strategic Plan & Objectives	PRM-01.1	Mechanisms exist to establish a: (1) Strategic security, compliance and resilience-specific business plan; and	5	
1.2(a)	IT strategy	strategic development of the institution's organisational and operational structure of IT and of IT services and other significant dependencies on third parties;	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	5	
1.2(a)	IT strategy	strategic development of the institution's organisational and operational structure of IT and of IT services and other significant dependencies on third parties;	Functional	Intersects With	Strategic Plan & Objectives	PRM-01.1	Mechanisms exist to establish a: (1) Strategic security, compliance and resilience-specific business plan; and	5	
1.2(b)	IT strategy	allocation to IT and information security of the generally established standards by which the institution abides;	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	5	
1.2(b)	IT strategy	allocation to IT and information security of the generally established standards by which the institution abides;	Functional	Intersects With	Strategic Plan & Objectives	PRM-01.1	Mechanisms exist to establish a: (1) Strategic security, compliance and resilience-specific business plan; and	5	
1.2(c)	IT strategy	goals, responsibilities and integration of information security into the organisation;	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	5	
1.2(c)	IT strategy	goals, responsibilities and integration of information security into the organisation;	Functional	Intersects With	Strategic Plan & Objectives	PRM-01.1	Mechanisms exist to establish a: (1) Strategic security, compliance and resilience-specific business plan; and	5	
1.2(d)	IT strategy	strategic development of IT architecture;	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	5	
1.2(d)	IT strategy	strategic development of IT architecture;	Functional	Intersects With	Strategic Plan & Objectives	PRM-01.1	Mechanisms exist to establish a: (1) Strategic security, compliance and resilience-specific business plan; and	5	
1.2(d)	IT strategy	strategic development of IT architecture;	Functional	Intersects With	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	5	
1.2(d)	IT strategy	strategic development of IT architecture;	Functional	Intersects With	Secure Architecture Principles	SEA-01.4	Mechanisms exist to ensure security, compliance and resilience capabilities are designed and maintained in alignment with security architecture principles from: (1) The Open Group Architecture Framework (TOGAF); (2) Sherwood Applied Business Security Architecture (SABSA); and/or (3) An organization-defined reference architecture.	5	
1.2(d)	IT strategy	strategic development of IT architecture;	Functional	Intersects With	Alignment With Enterprise Architecture	SEA-02	Mechanisms exist to develop an enterprise architecture, aligned with industry-recognized leading practices, with consideration for security, compliance and resilience principles that addresses risk to organizational operations, assets, individuals and other organizations.	5	
1.2(e)	IT strategy	statements on IT service continuity management giving due consideration to information security requirements;	Functional	Intersects With	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BCDR) playbooks).	5	
1.2(e)	IT strategy	statements on IT service continuity management giving due consideration to information security requirements;	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	5	
1.2(e)	IT strategy	statements on IT service continuity management giving due consideration to information security requirements;	Functional	Intersects With	Strategic Plan & Objectives	PRM-01.1	Mechanisms exist to establish a: (1) Strategic security, compliance and resilience-specific business plan; and	5	
1.2(f)	IT strategy	statements on IT systems developed and/or run by the organisational units themselves (hardware and software components).	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	5	
1.2(f)	IT strategy	statements on IT systems developed and/or run by the organisational units themselves (hardware and software components).	Functional	Intersects With	Strategic Plan & Objectives	PRM-01.1	Mechanisms exist to establish a: (1) Strategic security, compliance and resilience-specific business plan; and	5	
1.2(f)	IT strategy	statements on IT systems developed and/or run by the organisational units themselves (hardware and software components).	Functional	Intersects With	Technology Development & Acquisition	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and procurement methods to meet unique business needs.	5	
2	IT governance	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
2.1	IT governance	IT governance is the structure used to manage and monitor the operation and further development of IT systems including the related IT processes on the basis of the IT strategy. The key regulations here are in particular those on the organisational and operational structure of IT (see AT 4.3.1 of MaRisk), information risk management and information security management (see AT 4.3.2 of MaRisk, AT 7.2 numbers 2 and 4 of MaRisk), the appropriateness of the quantity and quality of the institution's IT staffing (see AT 7.1 of MaRisk) as well as the scope and quality of technical and organisational resources (see AT 7.2 number 1 of MaRisk). Regulations governing the organisational and operational structure of IT shall be swiftly amended in the event of modifications to the activities and processes (see AT 5 numbers 1 and 2 of MaRisk).	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	5	
2.1	IT governance	IT governance is the structure used to manage and monitor the operation and further development of IT systems including the related IT processes on the basis of the IT strategy. The key regulations here are in particular those on the organisational and operational structure of IT (see AT 4.3.1 of MaRisk), information risk management and information security management (see AT 4.3.2 of MaRisk, AT 7.2 numbers 2 and 4 of MaRisk), the appropriateness of the quantity and quality of the institution's IT staffing (see AT 7.1 of MaRisk) as well as the scope and quality of technical and organisational resources (see AT 7.2 number 1 of MaRisk). Regulations governing the organisational and operational structure of IT shall be swiftly amended in the event of modifications to the activities and processes (see AT 5 numbers 1 and 2 of MaRisk).	Functional	Intersects With	Secure Practices Alignment Justification	GOV-01.4	Mechanisms exist to align the organization's Security, Compliance & Resilience Program (SCRP) with one or more industry-recognized frameworks that: (1) Support external scrutiny; and (2) Provide defensible justification for secure practices.	5	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Germany - Banking Supervisory Requirements for IT (2017)**

Focal Document URL: https://www.bafin.de/SharedDocs/Downloads/EN/Rundschreiben/dL/rs_1710_ba_BAIT_en.html?sessionid=CDFE3798FF983139E1E73C57

Published STRM URL: <https://content.securecontrolsframework.com/strm/riscf-strm-emea-deu-bsrit-2017.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
2.1	IT governance	IT governance is the structure used to manage and monitor the operation and further development of IT systems including the related IT processes on the basis of the IT strategy. The key regulations here are in particular those on the organisational and operational structure of IT (see AT 4.3.1 of MaRisk), information risk management and information security management (see AT 4.3.2 of MaRisk, AT 7.2 numbers 2 and 4 of MaRisk), the appropriateness of the quantity and quality of the institution's IT staffing (see AT 7.1 of MaRisk) as well as the scope and quality of technical and organisational resources (see AT 7.2 number 1 of MaRisk). Regulations governing the organisational and operational structure of IT shall be swiftly amended in the event of modifications to the activities and processes (see AT 5 numbers 1 and 2 of MaRisk).	Functional	Intersects With	Statutory, Regulatory & Contractual Compliance	CPL-01	Mechanisms exist to facilitate the identification and implementation of relevant statutory, regulatory and contractual controls.	5	
2.2	IT governance	The management board is responsible for ensuring that the regulations governing the organisational and operational structure of IT are defined on the basis of the IT strategy and are swiftly amended in the event of modifications to the activities and processes. The institution shall ensure that these regulations are implemented effectively.	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	8	
2.2	IT governance	The management board is responsible for ensuring that the regulations governing the organisational and operational structure of IT are defined on the basis of the IT strategy and are swiftly amended in the event of modifications to the activities and processes. The institution shall ensure that these regulations are implemented effectively.	Functional	Intersects With	Commitment To Continual Improvements	GOV-01.3	Mechanisms exist to commit appropriate resources needed for continual improvement of the organization's Security, Compliance & Resilience Program (SCRPs), including: (1) Staffing; (2) Budget; (3) Processes; and (4) Technologies.	3	
2.3	IT governance	The institution shall ensure that appropriate resources, in terms of both quality and quantity, are available for information risk management, information security management, IT operations and application development in particular.	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	8	
2.3	IT governance	The institution shall ensure that appropriate resources, in terms of both quality and quantity, are available for information risk management, information security management, IT operations and application development in particular.	Functional	Intersects With	Security, Compliance & Resilience Protection Portfolio Management	PRM-01	Mechanisms exist to facilitate the implementation of resource planning controls that provide a portfolio management approach to achieve security, compliance and resilience objectives.	5	
2.3	IT governance	The institution shall ensure that appropriate resources, in terms of both quality and quantity, are available for information risk management, information security management, IT operations and application development in particular.	Functional	Intersects With	Security, Compliance & Resilience Resource Management	PRM-02	Mechanisms exist to address all capital planning and investment requests, including the resources needed to implement the Security, Compliance & Resilience Program (SCRPs) and document all exceptions to this requirement.	8	
2.3	IT governance	The institution shall ensure that appropriate resources, in terms of both quality and quantity, are available for information risk management, information security management, IT operations and application development in particular.	Functional	Intersects With	Allocation of Resources	PRM-03	Mechanisms exist to identify and allocate resources for management, operational, technical and data protection requirements within business process planning for projects / initiatives.	8	
2.4	IT governance	Conflicts of interest and activities that are not compatible with each other shall be avoided within the organisational and operational structure of IT.	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	5	
2.5	IT governance	The management board shall define appropriate quantitative or qualitative criteria for managing those areas responsible for operations and for the further development of IT systems. Compliance with the criteria shall be monitored.	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	8	
2.5	IT governance	The management board shall define appropriate quantitative or qualitative criteria for managing those areas responsible for operations and for the further development of IT systems. Compliance with the criteria shall be monitored.	Functional	Intersects With	Measures of Performance	GOV-05	Mechanisms exist to develop, report and monitor Security, Compliance & Resilience Program (SCRPs) measures of performance.	5	
3	Information risk management	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
3.1	Information risk management	The processing and sharing of information in business and service processes is supported by data processing IT systems and related IT processes. The scope and quality thereof shall be based, in particular, on the institution's internal operating needs, business activities and risk situation (see AT 7.2 number 1 of MaRisk). The IT systems, the related IT processes and the other components of the information domain shall ensure the integrity, availability, authenticity and confidentiality of the data (see AT 7.2 number 2 of MaRisk). The institution shall define and coordinate the tasks, competencies, responsibilities, controls and reporting channels required for the management of information risk (see AT 4.3.1 number 2 of MaRisk). To this end, the institution shall set up appropriate monitoring and steering processes (see AT 7.2 number 4 of MaRisk) and define the related reporting requirements (see BT 3.2 number 1 of MaRisk).	Functional	Subset Of	Security, Compliance & Resilience Program (SCRPs)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	10	
3.1	Information risk management	The processing and sharing of information in business and service processes is supported by data processing IT systems and related IT processes. The scope and quality thereof shall be based, in particular, on the institution's internal operating needs, business activities and risk situation (see AT 7.2 number 1 of MaRisk). The IT systems, the related IT processes and the other components of the information domain shall ensure the integrity, availability, authenticity and confidentiality of the data (see AT 7.2 number 2 of MaRisk). The institution shall define and coordinate the tasks, competencies, responsibilities, controls and reporting channels required for the management of information risk (see AT 4.3.1 number 2 of MaRisk). To this end, the institution shall set up appropriate monitoring and steering processes (see AT 7.2 number 4 of MaRisk) and define the related reporting requirements (see BT 3.2 number 1 of MaRisk).	Functional	Intersects With	Risk Management Program	RSK-01	Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned with: (1) The organization's Enterprise Risk Management (ERM); and (2) Industry-recognized cybersecurity risk management practices.	8	
3.2	Information risk management	The components of an information risk management system shall be implemented in line with the competencies of all the key parties and functions involved and with no conflicts of interest.	Functional	Subset Of	Risk Management Program	RSK-01	Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned with:	10	
3.3	Information risk management	The institution shall have an up-to-date overview of the components of the defined information domain as well as any related dependencies and interfaces. The institution shall be guided in this respect in particular by internal operating needs, business activities and the risk situation.	Functional	Intersects With	Asset-Service Dependencies	AST-01.1	Mechanisms exist to identify and assess the security of Technology Assets, Applications and/or Services (TAAS) that support more than one critical business function.	5	
3.3	Information risk management	The institution shall have an up-to-date overview of the components of the defined information domain as well as any related dependencies and interfaces. The institution shall be guided in this respect in particular by internal operating needs, business activities and the risk situation.	Functional	Intersects With	Asset Inventories	AST-02	Mechanisms exist to perform inventories of Technology Assets, Applications, Services and/or Data (TAASD) that: (1) Accurately reflects the current TAASD in use; (2) Identifies authorized software products, including business justification details; (3) Is at the level of granularity deemed necessary for tracking and reporting; (4) Includes organization-defined information deemed necessary to achieve effective property accountability; and (5) Is available for review and audit by designated organizational personnel.	5	
3.3	Information risk management	The institution shall have an up-to-date overview of the components of the defined information domain as well as any related dependencies and interfaces. The institution shall be guided in this respect in particular by internal operating needs, business activities and the risk situation.	Functional	Intersects With	Risk Catalog	RSK-03.1	Mechanisms exist to develop and keep current a catalog of applicable risks associated with the organization's business operations and technologies in use.	5	
3.3	Information risk management	The institution shall have an up-to-date overview of the components of the defined information domain as well as any related dependencies and interfaces. The institution shall be guided in this respect in particular by internal operating needs, business activities and the risk situation.	Functional	Intersects With	Threat Catalog	THR-09	Mechanisms exist to develop and keep current a catalog of applicable internal and external threats to the organization, both natural and manmade.	5	
3.4	Information risk management	The institution shall determine the protection requirements for the components of its defined information domain, in particular with regard to the protection objectives of "integrity", "availability", "confidentiality" and "authenticity", on a regular and event-related basis. The owners of the information and the organisational units that are responsible for the business processes shall be responsible for determining the protection requirements.	Functional	Intersects With	Operationalizing Security, Compliance & Resilience Capabilities	GOV-15	Mechanisms exist to compel data and/or process owners to operationalize security, compliance and resilience practices for Technology Assets, Applications, Services and/or Data (TAASD) under their control.	5	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Germany - Banking Supervisory Requirements for IT (2017)**

Focal Document URL: https://www.bafin.de/SharedDocs/Downloads/EN/Rundschreiben/dL_rs_1710_ba_BAIT_en.html?sessionid=CDFE3798FF983139E1E73C57

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-emea-deu-bsrit-2017.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
3.4	Information risk management	The institution shall determine the protection requirements for the components of its defined information domain, in particular with regard to the protection objectives of "integrity", "availability", "confidentiality" and "authenticity", on a regular and event-related basis. The owners of the information and the organisational units that are responsible for the business processes shall be responsible for determining the protection requirements.	Functional	Intersects With	Select Controls	GOV-15.1	Mechanisms exist to compel data and/or process owners to select required security, compliance and resilience controls for Technology Assets, Applications, Services and/or Data (TAASD) under their control.	5	
3.4	Information risk management	The institution shall determine the protection requirements for the components of its defined information domain, in particular with regard to the protection objectives of "integrity", "availability", "confidentiality" and "authenticity", on a regular and event-related basis. The owners of the information and the organisational units that are responsible for the business processes shall be responsible for determining the protection requirements.	Functional	Intersects With	Implement Controls	GOV-15.2	Mechanisms exist to compel data and/or process owners to implement required security, compliance and resilience controls for Technology Assets, Applications, Services and/or Data (TAASD) under their control.	5	
3.4	Information risk management	The institution shall determine the protection requirements for the components of its defined information domain, in particular with regard to the protection objectives of "integrity", "availability", "confidentiality" and "authenticity", on a regular and event-related basis. The owners of the information and the organisational units that are responsible for the business processes shall be responsible for determining the protection requirements.	Functional	Intersects With	Risk Owner	RSK-03.2	Mechanisms exist to identify a risk owner for each item in the risk register to ensure clear accountability for unremediated risks.	5	
3.4	Information risk management	The institution shall determine the protection requirements for the components of its defined information domain, in particular with regard to the protection objectives of "integrity", "availability", "confidentiality" and "authenticity", on a regular and event-related basis. The owners of the information and the organisational units that are responsible for the business processes shall be responsible for determining the protection requirements.	Functional	Intersects With	Executive Leadership Approval For Managing Material Risk	RSK-13	Mechanisms exist to obtain executive leadership approval for risk management decisions involving material risk.	5	
3.5	Information risk management	The determination of the protection requirements and the related documentation shall be reviewed by information risk management.	Functional	Subset Of	Risk Management Program	RSK-01	Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned	10	
3.6	Information risk management	The institution shall define and suitably document requirements that are appropriate for achieving the relevant protection requirements (catalogue of target measures).	Functional	Intersects With	Operationalizing Security, Compliance & Resilience Capabilities	GOV-15	Mechanisms exist to compel data and/or process owners to operationalize security, compliance and resilience practices for Technology Assets, Applications, Services and/or Data (TAASD) under their control.	5	
3.6	Information risk management	The institution shall define and suitably document requirements that are appropriate for achieving the relevant protection requirements (catalogue of target measures).	Functional	Intersects With	Select Controls	GOV-15.1	Mechanisms exist to compel data and/or process owners to select required security, compliance and resilience controls for Technology Assets, Applications, Services and/or Data (TAASD) under their control.	5	
3.6	Information risk management	The institution shall define and suitably document requirements that are appropriate for achieving the relevant protection requirements (catalogue of target measures).	Functional	Intersects With	Applied Security, Compliance and Resilience Controls Documentation	IAO-03	Mechanisms exist to generate authoritative documentation (e.g., System Security Plan (SSP)) that: (1) Identifies key architectural and implementation information on in-scope Technology Assets, Applications and/or Services (TAAS); (2) Reflects the current state of applied security, compliance and resilience controls on applicable People, Processes, Technologies, Data and/or Facilities (PTPDF) that are contained within the system boundary; and (3) Provides a historical record of applied security controls, including changes.	5	
3.7	Information risk management	The institution shall compare the target measures with the measures that have already been effectively implemented in each case (actual measures) on the basis of the defined risk criteria.	Functional	Intersects With	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	8	
3.8	Information risk management	Other risk mitigation measures, due to target measures not being completely implemented, shall be effectively coordinated, documented, monitored and managed.	Functional	Intersects With	Capabilities Deficiency Tracking	IAO-05	Mechanisms exist to govern identified deficiencies (e.g., Plan of Action and Milestones (POA&M) or similar methodology) that formally documents, at a minimum: (1) Deficiency tracking number; (2) Applicable security, compliance and/or resilience control; (3) Description of the deficiency(ies); (4) Risk associated with the deficiency(ies); (5) Source deficiency identification/detection; (6) Temporary compensating controls, if applicable; (7) Point of Contact (POC) (e.g., asset/process owner); (8) Resources required to conduct remediation actions; (9) Planned remedial actions to the deficiency(ies); (10) Proposed remediation timeline; and (11) Disposition statement (e.g., closeout summary).	8	
3.9	Information risk management	Information management shall coordinate and monitor the risk analysis and transfer its results into the operational risk management process. The handling of risks shall be approved in line with the competencies.	Functional	Intersects With	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	5	
3.9	Information risk management	Information management shall coordinate and monitor the risk analysis and transfer its results into the operational risk management process. The handling of risks shall be approved in line with the competencies.	Functional	Intersects With	Risk Treatment Options	RSK-06.3	Mechanisms exist to select appropriate risk treatment options, based on applicable risk assessment findings, including: (1) Mitigating the risk to an acceptable level; (2) Avoiding the risk (e.g., terminating the project); (3) Transferring the risk to a third party (e.g., insurance, service provider, etc.); or (4) Accepting the risk.	8	
3.10	Information risk management	The institution shall keep itself informed about all threats to and weaknesses in its information domain, examine their relevance, assess their impact and, if necessary, take appropriate technical and organisational measures.	Functional	Subset Of	Threat Intelligence Program	THR-01	Mechanisms exist to implement a threat intelligence program that includes a cross-organization information-sharing capability that can influence the development of the system and security architectures, selection of security solutions, monitoring, threat hunting, response and recovery activities.	10	
3.10	Information risk management	The institution shall keep itself informed about all threats to and weaknesses in its information domain, examine their relevance, assess their impact and, if necessary, take appropriate technical and organisational measures.	Functional	Intersects With	Threat Intelligence Feeds	THR-03	Mechanisms exist to maintain situational awareness of vulnerabilities and evolving threats by leveraging the knowledge of attacker tactics, techniques and procedures to facilitate the implementation of preventative and compensating controls.	5	
3.10	Information risk management	The institution shall keep itself informed about all threats to and weaknesses in its information domain, examine their relevance, assess their impact and, if necessary, take appropriate technical and organisational measures.	Functional	Intersects With	Threat Catalog	THR-09	Mechanisms exist to develop and keep current a catalog of applicable internal and external threats to the organization, both natural and manmade.	5	
3.10	Information risk management	The institution shall keep itself informed about all threats to and weaknesses in its information domain, examine their relevance, assess their impact and, if necessary, take appropriate technical and organisational measures.	Functional	Intersects With	Threat Analysis	THR-10	Mechanisms exist to identify, assess, prioritize and document the potential impact(s) and likelihood(s) of applicable internal and external threats.	5	
3.11	Information risk management	The management board shall be informed regularly, but at least once a quarter, in particular about the results of the risk analysis as well as any changes in the risk situation.	Functional	Intersects With	Status Reporting To Governing Body	GOV-01.2	Mechanisms exist to provide governance oversight reporting and recommendations to those entrusted to make executive decisions about matters considered material to the organization's Security, Compliance & Resilience Program (SCRCP).	8	
4	Information security management	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
4.1	Information security management	Information security management makes provisions for information security, defines processes and manages the implementation thereof (see AT 7.2 number 2 of MaRisk). Information security management follows a continuous process that comprises a planning, implementation, success monitoring, optimisation and improvement phase. The content of the information security officer's reporting requirements to the management board as well as the frequency of reporting shall be based on BT 3.2 number 1 of MaRisk.	Functional	Subset Of	Security, Compliance & Resilience Program (SCRCP)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	10	
4.2	Information security management	The management board shall agree an information security policy and communicate this within the institution. The information security policy shall be in line with the institution's strategies. The policy shall be reviewed in the event of significant changes in the overall conditions and modified promptly if required.	Functional	Intersects With	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	8	
4.2	Information security management	The management board shall agree an information security policy and communicate this within the institution. The information security policy shall be in line with the institution's strategies. The policy shall be reviewed in the event of significant changes in the overall conditions and modified promptly if required.	Functional	Intersects With	Periodic Review & Update of Security, Compliance & Resilience Program	GOV-03	Mechanisms exist to review the Security, Compliance & Resilience Program (SCRCP), including policies, standards and procedures, at planned intervals or if significant changes occur to ensure their continuing suitability, adequacy and effectiveness.	5	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Germany - Banking Supervisory Requirements for IT (2017)**

Focal Document URL: https://www.bafin.de/SharedDocs/Downloads/EN/Rundschreiben/dLrs_1710_ba_BAIT_en.html?sessionid=CDFE3798FF983139E1E73C57

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-emea-deu-bsrit-2017.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
4.3	Information security management	Based on the information security policy and the results of information risk management, more specific, state-of-the-art information security policies and information security processes shall be defined.	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	5	
4.4	Information security management	The management board shall establish an information security officer function. This function is responsible for all information security issues within the institution and with regard to third parties. It ensures that information security objectives and measures defined in the institution's IT strategy, information security policy and information security guidelines are transparent both within the institution and for third parties, and that compliance with them is reviewed and monitored regularly and on an event-driven basis.	Functional	Intersects With	Commitment To Continual Improvements	GOV-01.3	Mechanisms exist to commit appropriate resources needed for continual improvement of the organization's Security, Compliance & Resilience Program (SCRPP), including: (1) Staffing; (2) Budget; (3) Processes; and (4) Technologies.	5	
4.4	Information security management	The management board shall establish an information security officer function. This function is responsible for all information security issues within the institution and with regard to third parties. It ensures that information security objectives and measures defined in the institution's IT strategy, information security policy and information security guidelines are transparent both within the institution and for third parties, and that compliance with them is reviewed and monitored regularly and on an event-driven basis.	Functional	Intersects With	Periodic Review & Update of Security, Compliance & Resilience Program	GOV-03	Mechanisms exist to review the Security, Compliance & Resilience Program (SCRPP), including policies, standards and procedures, at planned intervals or if significant changes occur to ensure their continuing suitability, adequacy and effectiveness.	5	
4.5	Information security management	In terms of organisation and processes, the information security officer function shall be independent to avoid any potential conflicts of interest.	Functional	Intersects With	Assigned Security, Compliance & Resilience Responsibilities	GOV-04	Mechanisms exist to assign one or more qualified individuals with the mission and resources to centrally-manage, coordinate, develop, implement and maintain an enterprise-wide Security, Compliance & Resilience Program (SCRPP).	5	
4.5	Information security management	In terms of organisation and processes, the information security officer function shall be independent to avoid any potential conflicts of interest.	Functional	Intersects With	Stakeholder Accountability Structure	GOV-04.1	Mechanisms exist to enforce an accountability structure so that appropriate teams and individuals are empowered, responsible and trained for mapping, measuring and managing Technology Assets, Applications, Services and/or Data (TAASD)-related risks.	5	
4.6	Information security management	As a rule, each institution shall have its own information security officer function in-house.	Functional	Intersects With	Assigned Security, Compliance & Resilience Responsibilities	GOV-04	Mechanisms exist to assign one or more qualified individuals with the mission and resources to centrally-manage, coordinate, develop, implement and maintain an enterprise-wide Security, Compliance & Resilience Program (SCRPP).	5	
4.6	Information security management	As a rule, each institution shall have its own information security officer function in-house.	Functional	Intersects With	Stakeholder Accountability Structure	GOV-04.1	Mechanisms exist to enforce an accountability structure so that appropriate teams and individuals are empowered, responsible and trained for mapping, measuring and managing Technology Assets, Applications, Services and/or Data (TAASD)-related risks.	5	
4.7	Information security management	After an information security incident, the impact on information security shall be analysed promptly and appropriate follow-up measures approved.	Functional	Subset Of	Incident Response Operations	IRO-01	Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response capability for cybersecurity and data protection-related incidents.	10	
4.7	Information security management	After an information security incident, the impact on information security shall be analysed promptly and appropriate follow-up measures approved.	Functional	Intersects With	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	5	
4.7	Information security management	After an information security incident, the impact on information security shall be analysed promptly and appropriate follow-up measures approved.	Functional	Intersects With	Incident Classification & Prioritization	IRO-02.4	Mechanisms exist to identify classes of incidents and actions to take to ensure the continuation of organizational missions and business functions.	5	
4.8	Information security management	The institution shall introduce a policy on testing and reviewing measures to protect information security and shall review it regularly and on an event-driven basis and modify it if necessary.	Functional	Subset Of	Security, Compliance & Resilience Program (SCRPP)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	10	
4.8	Information security management	The institution shall introduce a policy on testing and reviewing measures to protect information security and shall review it regularly and on an event-driven basis and modify it if necessary.	Functional	Intersects With	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	8	
4.9	Information security management	The institution shall define a continuous and appropriate awareness and training programme for information security. The success of the defined awareness and training measures shall be reviewed.	Functional	Intersects With	Measures of Performance	GOV-05	Mechanisms exist to develop, report and monitor Security, Compliance & Resilience Program (SCRPP) measures of performance.	5	
4.9	Information security management	The institution shall define a continuous and appropriate awareness and training programme for information security. The success of the defined awareness and training measures shall be reviewed.	Functional	Subset Of	Security, Compliance & Resilience-Minded Workforce	SAT-01	Mechanisms exist to facilitate the implementation of security workforce development and awareness controls.	10	
4.9	Information security management	The institution shall define a continuous and appropriate awareness and training programme for information security. The success of the defined awareness and training measures shall be reviewed.	Functional	Intersects With	Maintaining Workforce Development Relevancy	SAT-01.1	Mechanisms exist to periodically review security workforce development and awareness training to account for changes to: (1) Organizational policies, standards and procedures; (2) Assigned roles and responsibilities; (3) Relevant threats and risks; and (4) Technological developments.	5	
4.10	Information security management	The information security officer shall report to the management board regularly, at least once a quarter, and on an ad hoc basis on the status of information security.	Functional	Intersects With	Status Reporting To Governing Body	GOV-01.2	Mechanisms exist to provide governance oversight reporting and recommendations to those entrusted to make executive decisions about matters considered material to the organization's Security, Compliance & Resilience Program (SCRPP).	8	
4.10	Information security management	The information security officer shall report to the management board regularly, at least once a quarter, and on an ad hoc basis on the status of information security.	Functional	Intersects With	Stakeholder Accountability Structure	GOV-04.1	Mechanisms exist to enforce an accountability structure so that appropriate teams and individuals are empowered, responsible and trained for mapping, measuring and managing Technology Assets, Applications, Services and/or Data (TAASD)-related risks.	3	
5	Operational information security	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
5.1	Operational information security	Operational information security implements information security management requirements. The IT systems, related IT processes and other components of the information domain shall ensure the integrity, availability, authenticity and confidentiality of the data. To ensure this, the design of the IT systems and related IT processes shall generally be based on established standards (see AT 7.2 number 2 of MaRisk). Appropriate monitoring and steering processes shall be established for IT risks, comprising in particular the definition of IT risk criteria, the identification of IT risks, the determination of the protection requirement, protective measures for IT operations derived from it, and the definition of measures to manage and mitigate risks (see AT 7.2 number 4 of MaRisk).	Functional	Subset Of	Operationalizing Security, Compliance & Resilience Capabilities	GOV-15	Mechanisms exist to compel data and/or process owners to operationalize security, compliance and resilience practices for Technology Assets, Applications, Services and/or Data (TAASD) under their control.	10	
5.1	Operational information security	Operational information security implements information security management requirements. The IT systems, related IT processes and other components of the information domain shall ensure the integrity, availability, authenticity and confidentiality of the data. To ensure this, the design of the IT systems and related IT processes shall generally be based on established standards (see AT 7.2 number 2 of MaRisk). Appropriate monitoring and steering processes shall be established for IT risks, comprising in particular the definition of IT risk criteria, the identification of IT risks, the determination of the protection requirement, protective measures for IT operations derived from it, and the definition of measures to manage and mitigate risks (see AT 7.2 number 4 of MaRisk).	Functional	Intersects With	Select Controls	GOV-15.1	Mechanisms exist to compel data and/or process owners to select required security, compliance and resilience controls for Technology Assets, Applications, Services and/or Data (TAASD) under their control.	8	
5.2	Operational information security	Based on the information security policy and the more specific information security policies, the institution shall implement state-of-the-art operational information security measures and processes.	Functional	Intersects With	Implement Controls	GOV-15.2	Mechanisms exist to compel data and/or process owners to implement required security, compliance and resilience controls for Technology Assets, Applications, Services and/or Data (TAASD) under their control.	8	
5.3	Operational information security	Threats to the information domain shall be identified as early as possible. Potentially security-related information shall be evaluated suitably promptly, using a rule-based approach, and centrally. This information shall be protected during transport and storage and shall be held available for an appropriate period for subsequent evaluation.	Functional	Intersects With	Threat Intelligence Program	THR-01	Mechanisms exist to implement a threat intelligence program that includes a cross-organization information-sharing capability that can influence the development of the system and security architectures, selection of security solutions, monitoring, threat hunting, response and recovery activities.	8	
5.3	Operational information security	Threats to the information domain shall be identified as early as possible. Potentially security-related information shall be evaluated suitably promptly, using a rule-based approach, and centrally. This information shall be protected during transport and storage and shall be held available for an appropriate period for subsequent evaluation.	Functional	Intersects With	Threat Intelligence Feeds	THR-03	Mechanisms exist to maintain situational awareness of vulnerabilities and evolving threats by leveraging the knowledge of attacker tactics, techniques and procedures to facilitate the implementation of preventative and compensating controls.	5	
5.3	Operational information security	Threats to the information domain shall be identified as early as possible. Potentially security-related information shall be evaluated suitably promptly, using a rule-based approach, and centrally. This information shall be protected during transport and storage and shall be held available for an appropriate period for subsequent evaluation.	Functional	Intersects With	Threat Catalog	THR-09	Mechanisms exist to develop and keep current a catalog of applicable internal and external threats to the organization, both natural and manmade.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
5.3	Operational information security	Threats to the information domain shall be identified as early as possible. Potentially security-related information shall be evaluated suitably promptly, using a rule-based approach, and centrally. This information shall be protected during transport and storage and shall be held available for an appropriate period for subsequent evaluation.	Functional	Intersects With	Threat Analysis	THR-10	Mechanisms exist to identify, assess, prioritize and document the potential impact(s) and likelihood(s) of applicable internal and external threats.	8	
5.4	Operational information security	An appropriate portfolio of rules for identifying security-related events shall be defined. Rules shall be tested before being put into operation. The rules shall be reviewed for effectiveness and updated regularly and on an event-driven basis.	Functional	Intersects With	Indicators of Compromise (IOC)	IRO-03	Mechanisms exist to define specific Indicators of Compromise (IOC) to identify the signs of potential cybersecurity events.	5	
5.4	Operational information security	An appropriate portfolio of rules for identifying security-related events shall be defined. Rules shall be tested before being put into operation. The rules shall be reviewed for effectiveness and updated regularly and on an event-driven basis.	Functional	Intersects With	Monitoring for Indicators of Compromise (IOC)	MON-11.3	Automated mechanisms exist to identify and alert on Indicators of Compromise (IoC).	5	
5.5	Operational information security	Security-related events shall be analysed promptly and information security management shall be responsible for responding appropriately to any resulting information security incidents.	Functional	Intersects With	Analyze and Prioritize Monitoring Requirements	MON-01.16	Mechanisms exist to assess the organization's needs for monitoring and prioritize the monitoring of Technology Assets, Applications and/or Services (TAAS), based on TAAS criticality and the sensitivity of the data	8	
5.5	Operational information security	Security-related events shall be analysed promptly and information security management shall be responsible for responding appropriately to any resulting information security incidents.	Functional	Intersects With	Anomalous Behavior	MON-16	Mechanisms exist to utilize User & Entity Behavior Analytics (UEBA) and/or User Activity Monitoring (UAM) solutions to detect and respond to anomalous behavior that could indicate account compromise or other malicious activities.	3	
5.6	Operational information security	The security of the IT systems shall be reviewed regularly, on an event-driven basis while avoiding any conflicts of interest. Results shall be analysed to establish any necessary improvements and risks shall be managed appropriately.	Functional	Intersects With	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	8	
5.6	Operational information security	The security of the IT systems shall be reviewed regularly, on an event-driven basis while avoiding any conflicts of interest. Results shall be analysed to establish any necessary improvements and risks shall be managed appropriately.	Functional	Intersects With	Functional Review Of Security, Compliance & Resilience Controls	CPL-03.2	Mechanisms exist to regularly review Technology Assets, Applications and/or Services (TAAS) for adherence to the organization's security, compliance and/or resilience policies and standards.	8	
6	Identity and access management	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
6.1	Identity and access management	Identity and access management ensures that access rights granted to users are in line with and used as defined in the institution's organisational and operational requirements. Identity and access management shall meet the requirements set out in A.4.3.1 number 2, AT 7.2 number 2 as well as BTO number 9 of MaRisk. All forms of access rights to components of the information domain should be subject to standardised processes and controls.	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	
6.2	Identity and access management	User access rights concepts define the scope and the conditions of use for access rights to IT systems (access to IT systems and access to data) and access rights to premises in a manner that is consistently in line with the determined protection requirements and can be completely and comprehensively derived from the concept for all access rights provided. User access rights concepts shall ensure that users are assigned access rights according to the need-to-know and leastprivilege principles, that the segregation of duties is observed across user access rights concepts and that conflicts of interest are avoided. User access rights concepts shall be reviewed regularly and on an event-driven basis and updated if necessary.	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	
6.3	Identity and access management	It shall be possible for access to IT systems to be unequivocally traced back to an active or responsible natural person at all times (wherever possible, automatically).	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient information to, at a minimum: (1) Establish what type of event occurred; (2) When (date and time) the event occurred; (3) Where the event occurred; (4) The source of the event; (5) The outcome (success or failure) of the event; and (6) The identity of any user/subject associated with the event.	8	
6.4	Identity and access management	Approval and control processes shall ensure compliance with the requirements contained in the user access rights concept when setting up, changing, deactivating or deleting access rights for users. The responsible organisational unit shall be appropriately involved, thus enabling it to fulfil its organisational responsibilities.	Functional	Intersects With	User Provisioning & De-Provisioning	IAC-07	Mechanisms exist to utilize a formal user registration and de-registration process that governs the assignment of access rights.	5	
6.4	Identity and access management	Approval and control processes shall ensure compliance with the requirements contained in the user access rights concept when setting up, changing, deactivating or deleting access rights for users. The responsible organisational unit shall be appropriately involved, thus enabling it to fulfil its organisational responsibilities.	Functional	Intersects With	Change of Roles & Duties	IAC-07.1	Mechanisms exist to revoke user access rights following changes in personnel roles and duties, if no longer necessary or permitted.	8	
6.4	Identity and access management	Approval and control processes shall ensure compliance with the requirements contained in the user access rights concept when setting up, changing, deactivating or deleting access rights for users. The responsible organisational unit shall be appropriately involved, thus enabling it to fulfil its organisational responsibilities.	Functional	Intersects With	Termination of Employment	IAC-07.2	Mechanisms exist to revoke user access rights in a timely manner, upon termination of employment or contract.	5	
6.5	Identity and access management	The control bodies responsible for setting up, changing, deactivating or deleting access rights shall be involved in reviewing whether access rights granted are still required and whether these comply with the requirements contained in the user access rights concept (recertification).	Functional	Intersects With	User Provisioning & De-Provisioning	IAC-07	Mechanisms exist to utilize a formal user registration and de-registration process that governs the assignment of access rights.	5	
6.5	Identity and access management	The control bodies responsible for setting up, changing, deactivating or deleting access rights shall be involved in reviewing whether access rights granted are still required and whether these comply with the requirements contained in the user access rights concept (recertification).	Functional	Intersects With	Change of Roles & Duties	IAC-07.1	Mechanisms exist to revoke user access rights following changes in personnel roles and duties, if no longer necessary or permitted.	8	
6.5	Identity and access management	The control bodies responsible for setting up, changing, deactivating or deleting access rights shall be involved in reviewing whether access rights granted are still required and whether these comply with the requirements contained in the user access rights concept (recertification).	Functional	Intersects With	Termination of Employment	IAC-07.2	Mechanisms exist to revoke user access rights in a timely manner, upon termination of employment or contract.	5	
6.6	Identity and access management	The setting up, changing, deactivating and deleting of access rights and recertification shall be documented in a way that facilitates comprehension and analysis.	Functional	Intersects With	User Provisioning & De-Provisioning	IAC-07	Mechanisms exist to utilize a formal user registration and de-registration process that governs the assignment of access rights.	5	
6.6	Identity and access management	The setting up, changing, deactivating and deleting of access rights and recertification shall be documented in a way that facilitates comprehension and analysis.	Functional	Intersects With	Change of Roles & Duties	IAC-07.1	Mechanisms exist to revoke user access rights following changes in personnel roles and duties, if no longer necessary or permitted.	8	
6.6	Identity and access management	The setting up, changing, deactivating and deleting of access rights and recertification shall be documented in a way that facilitates comprehension and analysis.	Functional	Intersects With	Termination of Employment	IAC-07.2	Mechanisms exist to revoke user access rights in a timely manner, upon termination of employment or contract.	5	
6.7	Identity and access management	The institution shall set up logging and monitoring processes consistent with the protection requirements and the target requirements that enable checks to be carried out to ensure that access rights are used only in the manner intended. Owing to the associated far-reaching intervention options, the institution shall in particular set up appropriate processes to log and monitor the activities with privileged (particularly critical) access rights.	Functional	Intersects With	Security Event Monitoring	MON-01.8	Mechanisms exist to review event logs on an ongoing basis and escalate incidents in accordance with established timelines and procedures.	5	
6.7	Identity and access management	The institution shall set up logging and monitoring processes consistent with the protection requirements and the target requirements that enable checks to be carried out to ensure that access rights are used only in the manner intended. Owing to the associated far-reaching intervention options, the institution shall in particular set up appropriate processes to log and monitor the activities with privileged (particularly critical) access rights.	Functional	Intersects With	Analyze and Prioritize Monitoring Requirements	MON-01.16	Mechanisms exist to assess the organization's needs for monitoring and prioritize the monitoring of Technology Assets, Applications and/or Services (TAAS), based on TAAS criticality and the sensitivity of the data it stores, transmits and processes.	5	
6.8	Identity and access management	Accompanying technical and organisational measures shall be implemented to ensure that the requirements contained in the user access rights concepts cannot be circumvented.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	5	
7	IT projects and application development	N/A	Functional	No Relationship	N/A	N/A	N/A	0	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
7.1	IT projects and application development	Material modifications to the IT systems in the course of IT projects, their impact on the organisational and operational structure of IT and on the related IT processes shall be evaluated as part of an impact analysis (see AT 8.2 number 1 of MaRisk). With respect to their first use and material modifications to IT systems, the requirements set out in AT 7.2 (in particular numbers 3 and 5) of MaRisk, AT 8.2 number 1 of MaRisk and AT 8.3 number 1 of MaRisk shall be met.	Functional	Intersects With	Security, Compliance & Resilience in Project Management	PRM-04	Mechanisms exist to assess security, compliance and resilience controls as part of Technology Assets, Applications and/or Services (TAAS) project development to determine whether controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting requirements.	5	
7.1	IT projects and application development	Material modifications to the IT systems in the course of IT projects, their impact on the organisational and operational structure of IT and on the related IT processes shall be evaluated as part of an impact analysis (see AT 8.2 number 1 of MaRisk). With respect to their first use and material modifications to IT systems, the requirements set out in AT 7.2 (in particular numbers 3 and 5) of MaRisk, AT 8.2 number 1 of MaRisk and AT 8.3 number 1 of MaRisk shall be met.	Functional	Intersects With	Secure Development Life Cycle (SDLC) Management	PRM-07	Mechanisms exist to ensure changes to Technology Assets, Applications and/or Services (TAAS) within the Secure Development Life Cycle (SDLC) are controlled through formal change control procedures.	8	
7.2	IT projects and application development	Rules shall be defined for the organisational framework of IT projects and the criteria for its application.	Functional	Intersects With	Security, Compliance & Resilience in Project Management	PRM-04	Mechanisms exist to assess security, compliance and resilience controls as part of Technology Assets, Applications and/or Services (TAAS) project development to determine whether controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting requirements.	5	
7.2	IT projects and application development	Rules shall be defined for the organisational framework of IT projects and the criteria for its application.	Functional	Intersects With	Secure Development Life Cycle (SDLC) Management	PRM-07	Mechanisms exist to ensure changes to Technology Assets, Applications and/or Services (TAAS) within the Secure Development Life Cycle (SDLC) are controlled through formal change control procedures.	8	
7.3	IT projects and application development	IT projects shall be managed appropriately, taking account of their objectives and risks in relation to duration, use of resources, and quality. To this end, model procedures shall be defined and compliance with them shall be monitored.	Functional	Intersects With	Security, Compliance & Resilience in Project Management	PRM-04	Mechanisms exist to assess security, compliance and resilience controls as part of Technology Assets, Applications and/or Services (TAAS) project development to determine whether controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting requirements.	5	
7.3	IT projects and application development	IT projects shall be managed appropriately, taking account of their objectives and risks in relation to duration, use of resources, and quality. To this end, model procedures shall be defined and compliance with them shall be monitored.	Functional	Intersects With	Secure Development Life Cycle (SDLC) Management	PRM-07	Mechanisms exist to ensure changes to Technology Assets, Applications and/or Services (TAAS) within the Secure Development Life Cycle (SDLC) are controlled through formal change control procedures.	8	
7.4	IT projects and application development	The portfolio of IT projects shall be monitored and managed appropriately. Due account shall be taken of the fact that risks can also stem from interdependencies between different projects.	Functional	Intersects With	Security, Compliance & Resilience Protection Portfolio Management	PRM-01	Mechanisms exist to facilitate the implementation of resource planning controls that provide a portfolio management approach to achieve security, compliance and resilience objectives.	8	
7.5	IT projects and application development	Material IT projects and IT project risks shall be reported to the management board regularly and on an event-driven basis. Material project risks shall be taken account of in the risk management.	Functional	Intersects With	Status Reporting To Governing Body	GOV-01.2	Mechanisms exist to provide governance oversight reporting and recommendations to those entrusted to make executive decisions about matters considered material to the organization's Security, Compliance & Resilience Program (SCRCP).	8	
7.5	IT projects and application development	Material IT projects and IT project risks shall be reported to the management board regularly and on an event-driven basis. Material project risks shall be taken account of in the risk management.	Functional	Intersects With	Security, Compliance & Resilience Protection Portfolio Management	PRM-01	Mechanisms exist to facilitate the implementation of resource planning controls that provide a portfolio management approach to achieve security, compliance and resilience objectives.	5	
7.6	IT projects and application development	Appropriate processes shall be defined for application development which contain specifications for identifying requirements, for the development objective, for (technical) implementation (including coding guidelines), for quality assurance, and for testing, approval and release.	Functional	Intersects With	Security, Compliance & Resilience Requirements Definition	PRM-05	Mechanisms exist to proactively govern Technology Assets, Applications and/or Services (TAAS) by: (1) Defining technical security, compliance and resilience requirements; and (2) Performing a criticality analysis at predefined decision points in the Secure Development Life Cycle (SDLC).	5	
7.6	IT projects and application development	Appropriate processes shall be defined for application development which contain specifications for identifying requirements, for the development objective, for (technical) implementation (including coding guidelines), for quality assurance, and for testing, approval and release.	Functional	Intersects With	Business Process Definition	PRM-06	Mechanisms exist to define business processes with consideration for security, compliance and resilience that determines: (1) The resulting risk to organizational operations, assets, individuals and other organizations; and (2) Information protection needs arising from the defined business processes and revises the processes as necessary, until an achievable set of protection needs is obtained.	5	
7.6	IT projects and application development	Appropriate processes shall be defined for application development which contain specifications for identifying requirements, for the development objective, for (technical) implementation (including coding guidelines), for quality assurance, and for testing, approval and release.	Functional	Intersects With	Secure Software Development Practices (SSDP)	TDA-06	Mechanisms exist to develop applications based on Secure Software Development Practices (SSDP).	5	
7.7	IT projects and application development	Requirements for the functionality of the application shall be compiled, evaluated, documented and approved in the same way as for non-functional requirements. Appropriate acceptance and test criteria shall be defined for each requirement. Responsibility for compiling, evaluating and approving the specialist requirements (functional and non-functional) lies with the responsible organisational units.	Functional	Intersects With	Technology Development & Acquisition	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and procurement methods to meet unique business needs.	5	
7.7	IT projects and application development	Requirements for the functionality of the application shall be compiled, evaluated, documented and approved in the same way as for non-functional requirements. Appropriate acceptance and test criteria shall be defined for each requirement. Responsibility for compiling, evaluating and approving the specialist requirements (functional and non-functional) lies with the responsible organisational units.	Functional	Intersects With	Product Management	TDA-01.1	Mechanisms exist to design and implement product management processes to proactively govern the design, development and production of Technology Assets, Applications and/or Services (TAAS) across the System Development Life Cycle (SDLC) to: (1) Improve functionality; (2) Enhance security and resiliency capabilities; (3) Correct security deficiencies; and (4) Conform with applicable statutory, regulatory and/or contractual obligations.	5	
7.7	IT projects and application development	Requirements for the functionality of the application shall be compiled, evaluated, documented and approved in the same way as for non-functional requirements. Appropriate acceptance and test criteria shall be defined for each requirement. Responsibility for compiling, evaluating and approving the specialist requirements (functional and non-functional) lies with the responsible organisational units.	Functional	Intersects With	Minimum Viable Product (MVP) Security Requirements	TDA-02	Mechanisms exist to design, develop and produce Technology Assets, Applications and/or Services (TAAS) in such a way that risk-based technical and functional specifications ensure Minimum Viable Product (MVP) criteria establish an appropriate level of security and resiliency based on applicable risks and threats.	5	
7.7	IT projects and application development	Requirements for the functionality of the application shall be compiled, evaluated, documented and approved in the same way as for non-functional requirements. Appropriate acceptance and test criteria shall be defined for each requirement. Responsibility for compiling, evaluating and approving the specialist requirements (functional and non-functional) lies with the responsible organisational units.	Functional	Intersects With	Secure Software Development Practices (SSDP)	TDA-06	Mechanisms exist to develop applications based on Secure Software Development Practices (SSDP).	8	
7.7	IT projects and application development	Requirements for the functionality of the application shall be compiled, evaluated, documented and approved in the same way as for non-functional requirements. Appropriate acceptance and test criteria shall be defined for each requirement. Responsibility for compiling, evaluating and approving the specialist requirements (functional and non-functional) lies with the responsible organisational units.	Functional	Intersects With	Security, Compliance & Resilience Testing Throughout Development	TDA-09	Mechanisms exist to require system developers/integrators consult with security, compliance and/or resilience personnel to: (1) Create and implement a Security Testing and Evaluation (ST&E) plan, or similar capability; (2) Implement a verifiable flaw remediation process to correct weaknesses and deficiencies identified during the control testing and evaluation process; and (3) Document the results.	5	
7.8	IT projects and application development	In the context of application development, appropriate arrangements shall be made, depending on the protection requirement, such that after each application goes live the confidentiality, integrity, availability and authenticity of the data to be processed are also comprehensively assured.	Functional	Intersects With	Technology Development & Acquisition	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and procurement methods to meet unique business needs.	5	
7.8	IT projects and application development	In the context of application development, appropriate arrangements shall be made, depending on the protection requirement, such that after each application goes live the confidentiality, integrity, availability and authenticity of the data to be processed are also comprehensively assured.	Functional	Intersects With	Product Management	TDA-01.1	Mechanisms exist to design and implement product management processes to proactively govern the design, development and production of Technology Assets, Applications and/or Services (TAAS) across the System Development Life Cycle (SDLC) to: (1) Improve functionality; (2) Enhance security and resiliency capabilities; (3) Correct security deficiencies; and (4) Conform with applicable statutory, regulatory and/or contractual obligations.	8	
7.8	IT projects and application development	In the context of application development, appropriate arrangements shall be made, depending on the protection requirement, such that after each application goes live the confidentiality, integrity, availability and authenticity of the data to be processed are also comprehensively assured.	Functional	Intersects With	Secure Software Development Practices (SSDP)	TDA-06	Mechanisms exist to develop applications based on Secure Software Development Practices (SSDP).	8	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
7.8	IT projects and application development	In the context of application development, appropriate arrangements shall be made, depending on the protection requirement, such that after each application goes live the confidentiality, integrity, availability and authenticity of the data to be processed are also comprehensively assured.	Functional	Intersects With	Security, Compliance & Resilience Testing Throughout Development	TDA-09	Mechanisms exist to require system developers/integrators consult with security, compliance and/or resilience personnel to: (1) Create and implement a Security Testing and Evaluation (ST&E) plan, or similar capability; (2) Implement a verifiable flaw remediation process to correct weaknesses and deficiencies identified during the control testing and evaluation process; and (3) Document the results.	8	
7.9	IT projects and application development	The integrity of the application (especially the source code) shall be appropriately safeguarded. In addition, arrangements shall be made to enable the identification of whether an application was unintentionally modified or deliberately manipulated, among other things.	Functional	Intersects With	Technology Development & Acquisition	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and procurement methods to meet unique business needs.	5	
7.9	IT projects and application development	The integrity of the application (especially the source code) shall be appropriately safeguarded. In addition, arrangements shall be made to enable the identification of whether an application was unintentionally modified or deliberately manipulated, among other things.	Functional	Intersects With	Product Management	TDA-01.1	Mechanisms exist to design and implement product management processes to proactively govern the design, development and production of Technology Assets, Applications and/or Services (TAAS) across the System Development Life Cycle (SDLC) to: (1) Improve functionality; (2) Enhance security and resiliency capabilities; (3) Correct security deficiencies; and (4) Conform with applicable statutory, regulatory and/or contractual obligations.	8	
7.9	IT projects and application development	The integrity of the application (especially the source code) shall be appropriately safeguarded. In addition, arrangements shall be made to enable the identification of whether an application was unintentionally modified or deliberately manipulated, among other things.	Functional	Intersects With	Secure Software Development Practices (SSDP)	TDA-06	Mechanisms exist to develop applications based on Secure Software Development Practices (SSDP).	8	
7.9	IT projects and application development	The integrity of the application (especially the source code) shall be appropriately safeguarded. In addition, arrangements shall be made to enable the identification of whether an application was unintentionally modified or deliberately manipulated, among other things.	Functional	Intersects With	Security, Compliance & Resilience Testing Throughout Development	TDA-09	Mechanisms exist to require system developers/integrators consult with security, compliance and/or resilience personnel to: (1) Create and implement a Security Testing and Evaluation (ST&E) plan, or similar capability; (2) Implement a verifiable flaw remediation process to correct weaknesses and deficiencies identified during the control testing and evaluation process; and (3) Document the results.	8	
7.9	IT projects and application development	The integrity of the application (especially the source code) shall be appropriately safeguarded. In addition, arrangements shall be made to enable the identification of whether an application was unintentionally modified or deliberately manipulated, among other things.	Functional	Intersects With	Access to Program Source Code	TDA-20	Mechanisms exist to limit privileges to change software resident within software libraries.	8	
7.10	IT projects and application development	The application and its development shall be documented in a clearly structured way and in a manner that is readily comprehensible for competent third parties.	Functional	Intersects With	Technology Development & Acquisition	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and procurement methods to meet unique business needs.	3	
7.10	IT projects and application development	The application and its development shall be documented in a clearly structured way and in a manner that is readily comprehensible for competent third parties.	Functional	Intersects With	Product Management	TDA-01.1	Mechanisms exist to design and implement product management processes to proactively govern the design, development and production of Technology Assets, Applications and/or Services (TAAS) across the System Development Life Cycle (SDLC) to: (1) Improve functionality; (2) Enhance security and resiliency capabilities; (3) Correct security deficiencies; and (4) Conform with applicable statutory, regulatory and/or contractual obligations.	5	
7.10	IT projects and application development	The application and its development shall be documented in a clearly structured way and in a manner that is readily comprehensible for competent third parties.	Functional	Intersects With	Secure Software Development Practices (SSDP)	TDA-06	Mechanisms exist to develop applications based on Secure Software Development Practices (SSDP).	5	
7.10	IT projects and application development	The application and its development shall be documented in a clearly structured way and in a manner that is readily comprehensible for competent third parties.	Functional	Intersects With	Security, Compliance & Resilience Testing Throughout Development	TDA-09	Mechanisms exist to require system developers/integrators consult with security, compliance and/or resilience personnel to: (1) Create and implement a Security Testing and Evaluation (ST&E) plan, or similar capability; (2) Implement a verifiable flaw remediation process to correct weaknesses and deficiencies identified during the control testing and evaluation process; and (3) Document the results.	5	
7.11	IT projects and application development	A methodology for testing applications prior to their first use and after material modifications shall be defined and introduced. The scope of the tests shall include the functionality of the application, the measures implemented to protect information and, if relevant, system performance under various stress scenarios. The responsible organisational units shall be responsible for performing acceptance tests. Test environments for performing the acceptance tests shall correspond to the production environment in aspects material to the test. Test activities and test results shall be documented.	Functional	Subset Of	Information Assurance (IA) Operations	IAO-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience assessment and authorization controls.	10	
7.11	IT projects and application development	A methodology for testing applications prior to their first use and after material modifications shall be defined and introduced. The scope of the tests shall include the functionality of the application, the measures implemented to protect information and, if relevant, system performance under various stress scenarios. The responsible organisational units shall be responsible for performing acceptance tests. Test environments for performing the acceptance tests shall correspond to the production environment in aspects material to the test. Test activities and test results shall be documented.	Functional	Intersects With	Assessments	IAO-02	Mechanisms exist to formally assess the security, compliance and resilience controls in Technology Assets, Applications and/or Services (TAAS) through Information Assurance Program (IAP) activities to determine the extent to which the controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting expected requirements.	5	
7.11	IT projects and application development	A methodology for testing applications prior to their first use and after material modifications shall be defined and introduced. The scope of the tests shall include the functionality of the application, the measures implemented to protect information and, if relevant, system performance under various stress scenarios. The responsible organisational units shall be responsible for performing acceptance tests. Test environments for performing the acceptance tests shall correspond to the production environment in aspects material to the test. Test activities and test results shall be documented.	Functional	Intersects With	Specialized Assessments	IAO-02.2	Mechanisms exist to conduct specialized assessments for: (1) Statutory, regulatory and contractual compliance obligations; (2) Monitoring capabilities; (3) Mobile devices; (4) Databases; (5) Application security; (6) Embedded technologies (e.g., IoT, OT, etc.); (7) Vulnerability management; (8) Malicious code; (9) Insider threats; (10) Performance/load testing; (11) Artificial Intelligence and Autonomous Technologies (AAT); and/or Mechanisms exist to perform Information Assurance Program (IAP) activities to evaluate the design, implementation and effectiveness of technical security, compliance and resilience controls.	5	
7.11	IT projects and application development	A methodology for testing applications prior to their first use and after material modifications shall be defined and introduced. The scope of the tests shall include the functionality of the application, the measures implemented to protect information and, if relevant, system performance under various stress scenarios. The responsible organisational units shall be responsible for performing acceptance tests. Test environments for performing the acceptance tests shall correspond to the production environment in aspects material to the test. Test activities and test results shall be documented.	Functional	Intersects With	Technical Verification	IAO-06	Mechanisms exist to ensure Technology Assets, Applications and/or Services (TAAS) are officially authorized prior to "go live" in a production environment.	8	
7.11	IT projects and application development	A methodology for testing applications prior to their first use and after material modifications shall be defined and introduced. The scope of the tests shall include the functionality of the application, the measures implemented to protect information and, if relevant, system performance under various stress scenarios. The responsible organisational units shall be responsible for performing acceptance tests. Test environments for performing the acceptance tests shall correspond to the production environment in aspects material to the test. Test activities and test results shall be documented.	Functional	Intersects With	Security Authorization	IAO-07	Mechanisms exist to ensure Technology Assets, Applications and/or Services (TAAS) are officially authorized prior to "go live" in a production environment.	5	
7.12	IT projects and application development	After the application goes live, any deviations from standard operations shall be monitored, their causes shall be investigated and, where appropriate, measures for subsequent improvement shall be taken.	Functional	Intersects With	Product Management	TDA-01.1	Mechanisms exist to design and implement product management processes to proactively govern the design, development and production of Technology Assets, Applications and/or Services (TAAS) across the System Development Life Cycle (SDLC) to: (1) Improve functionality; (2) Enhance security and resiliency capabilities; (3) Correct security deficiencies; and (4) Conform with applicable statutory, regulatory and/or contractual obligations.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
7.12	IT projects and application development	After the application goes live, any deviations from standard operations shall be monitored, their causes shall be investigated and, where appropriate, measures for subsequent improvement shall be taken.	Functional	Intersects With	Ongoing Product Security Support	TDA-02.9	Mechanisms exist to deliver security updates to Technology Assets, Applications and/or Services (TAAS), where applicable, through: (1) Automatic updates; and (2) Notification of available updates to affected users.	5	
7.12	IT projects and application development	After the application goes live, any deviations from standard operations shall be monitored, their causes shall be investigated and, where appropriate, measures for subsequent improvement shall be taken.	Functional	Intersects With	Security, Compliance & Resilience Testing Throughout Development	TDA-09	Mechanisms exist to require system developers/integrators consult with security, compliance and/or resilience personnel to: (1) Create and implement a Security Testing and Evaluation (ST&E) plan, or similar capability; (2) Implement a verifiable flaw remediation process to correct weaknesses and deficiencies identified during the control testing and evaluation process; and (3) Document the results.	3	
7.13	IT projects and application development	An appropriate procedure shall be defined for the classification/categorisation (protection requirements category) and handling of the applications developed or run by the business unit's staff (end-user computing – EUC).	Functional	Intersects With	Data & Asset Classification	DCH-02	Mechanisms exist to ensure data and assets are categorized in accordance with applicable statutory, regulatory and contractual requirements.	5	
7.13	IT projects and application development	An appropriate procedure shall be defined for the classification/categorisation (protection requirements category) and handling of the applications developed or run by the business unit's staff (end-user computing – EUC).	Functional	Intersects With	Product Management	TDA-01.1	Mechanisms exist to design and implement product management processes to proactively govern the design, development and production of Technology Assets, Applications and/or Services (TAAS) across the System Development Life Cycle (SDLC) to: (1) Improve functionality; (2) Enhance security and resiliency capabilities; (3) Correct security deficiencies; and (4) Conform with applicable statutory, regulatory and/or contractual obligations.	5	
7.14	IT projects and application development	Rules shall be defined on the identification of all applications developed or run by the organisational unit's staff, on documentation, on the coding guidelines and on the testing methodology, on the protection requirements analysis and on the recertification process for authorisations (e.g. in EUC guidelines).	Functional	Intersects With	Data & Asset Classification	DCH-02	Mechanisms exist to ensure data and assets are categorized in accordance with applicable statutory, regulatory and contractual requirements.	5	
7.14	IT projects and application development	Rules shall be defined on the identification of all applications developed or run by the organisational unit's staff, on documentation, on the coding guidelines and on the testing methodology, on the protection requirements analysis and on the recertification process for authorisations (e.g. in EUC guidelines).	Functional	Intersects With	Product Management	TDA-01.1	Mechanisms exist to design and implement product management processes to proactively govern the design, development and production of Technology Assets, Applications and/or Services (TAAS) across the System Development Life Cycle (SDLC) to: (1) Improve functionality; (2) Enhance security and resiliency capabilities; (3) Correct security deficiencies; and (4) Conform with applicable statutory, regulatory and/or contractual obligations.	5	
8	IT operations	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
8.1	IT operations	IT operations shall fulfil the requirements resulting from the implementation of the business strategy as well as from the IT-supported business processes (see AT 7.2 numbers 1 and 2 of MaRisk).	Functional	Intersects With	Service Delivery (Business Process Support)	OPS-03	Mechanisms exist to define supporting business processes and implement appropriate governance and service management to ensure appropriate planning, delivery and support of the organization's technology capabilities supporting business functions, workforce, and/or customers based on industry-recognized standards to achieve the specific goals of the process area.	3	
8.2	IT operations	The components of the IT systems and their connections with each other shall be administered in a suitable way, and the inventory data collected for this shall be updated regularly and on an ad hoc basis.	Functional	Intersects With	Asset Inventories	AST-02	Mechanisms exist to perform inventories of Technology Assets, Applications, Services and/or Data (TAASD) that: (1) Accurately reflects the current TAASD in use; (2) Identifies authorized software products, including business justification details; (3) Is at the level of granularity deemed necessary for tracking and reporting; (4) Includes organization-defined information deemed necessary to achieve effective property accountability; and (5) Is available for review and audit by designated organizational personnel.	8	
8.3	IT operations	The portfolio of IT systems shall be managed. IT systems should be regularly updated. Risks from outdated IT systems or those no longer supported by the vendor shall be managed (lifecycle management).	Functional	Intersects With	Security, Compliance & Resilience Protection Portfolio Management	PRM-01	Mechanisms exist to facilitate the implementation of resource planning controls that provide a portfolio management approach to achieve security, compliance and resilience objectives.	8	
8.3	IT operations	The portfolio of IT systems shall be managed. IT systems should be regularly updated. Risks from outdated IT systems or those no longer supported by the vendor shall be managed (lifecycle management).	Functional	Intersects With	Technology Lifecycle Management	SEA-07.1	Mechanisms exist to manage the usable lifecycles of Technology Assets, Applications and/or Services (TAAS).	8	
8.4	IT operations	The processes for changing IT systems shall be designed and implemented depending on their nature, scale, complexity and riskiness. This shall also apply to newly procured or replaced IT systems as well as to security-related subsequent improvements (security patches).	Functional	Intersects With	Change Management Program	CHG-01	Mechanisms exist to facilitate the implementation of a change management program.	8	
8.5	IT operations	Changes to IT systems shall be accepted, documented, evaluated taking due account of potential implementation risks, prioritised and approved in an orderly way, and implemented in a coordinated and secure way. Appropriate processes shall also be established for timecritical changes to IT systems.	Functional	Intersects With	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	5	
8.6	IT operations	Reports of unscheduled deviations from standard operations (disruptions) and their causes shall, in a suitable way, be recorded, evaluated, prioritised with particular regard to potentially resulting risks, and escalated according to defined criteria. To this end, standard procedures shall be defined, e.g. for measures and communication and responsibilities (e.g. for malicious code on terminal devices, malfunctions). The processing, analysis of causes, and identification of solutions, including follow-up, shall be documented. An orderly process for the analysis of possible correlations between disruptions and of their causes shall be in place. The processing status of outstanding reports of disruptions, as well as the appropriateness of the evaluation and prioritisation, shall be monitored and managed. The institution shall define suitable criteria for informing the bodies concerned (e.g. management board, competent supervisory authority) about disruptions.	Functional	Intersects With	Respond To Unauthorized Changes	CFG-02.8	Mechanisms exist to respond to unauthorized changes to configuration settings as security incidents.	5	
8.7	IT operations	The provisions governing the data backup procedures (excluding data archiving) shall be set out in writing in a data backup strategy. The requirements contained in the data backup strategy for the availability, readability and timeliness of the customer and business data as well as for the IT systems required to process them shall be derived from the requirements for the business processes and from the business continuity plans. The procedures for recovery and safeguarding the readability of data shall be tested regularly, at least once a year, as part of a sample as well as on an event-driven basis.	Functional	Intersects With	Data Backups	BCD-11	Mechanisms exist to create recurring backups of data, software and/or system images, as well as verify the integrity of these backups, to ensure the availability of the data to satisfy Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).	8	
8.8	IT operations	The current performance and capacity requirements of the IT systems shall be captured. The future performance and capacity requirements shall be estimated. Performance delivery shall be planned and monitored, in particular in order to identify bottlenecks promptly and to respond to them appropriately. The performance and capacity requirements of information security measures shall be taken into account in the planning.	Functional	Intersects With	Capacity & Performance Management	CAP-01	Mechanisms exist to facilitate the implementation of capacity management controls to ensure optimal system performance to meet expected and anticipated future capacity requirements.	8	
8.8	IT operations	The current performance and capacity requirements of the IT systems shall be captured. The future performance and capacity requirements shall be estimated. Performance delivery shall be planned and monitored, in particular in order to identify bottlenecks promptly and to respond to them appropriately. The performance and capacity requirements of information security measures shall be taken into account in the planning.	Functional	Intersects With	Capacity Planning	CAP-03	Mechanisms exist to conduct capacity planning so that necessary capacity for information processing, telecommunications and environmental support will exist during contingency operations.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
8.8	IT operations	The current performance and capacity requirements of the IT systems shall be captured. The future performance and capacity requirements shall be estimated. Performance delivery shall be planned and monitored, in particular in order to identify bottlenecks promptly and to respond to them appropriately. The performance and capacity requirements of information security measures shall be taken into account in the planning.	Functional	Intersects With	Performance Monitoring	CAP-04	Automated mechanisms exist to centrally-monitor and alert on the operating state and health status of critical Technology Assets, Applications and/or Services (TAAS).	5	
9	Outsourcing and other external procurement of IT services	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
9.1	Outsourcing and other external procurement of IT services	IT services encompass all forms of IT procurement; in particular, this includes the provision of IT systems, projects/computer-aided construction projects or staff. Outsourcing of IT services shall meet the requirements pursuant to AT 9 of MaRisk. This shall also apply to the outsourcing of IT services which are provided to the institution by a services firm via a network (e.g. processing, storage, platforms or software) and which are supplied, used and invoiced dynamically and tailored to requirements via defined technical interfaces and protocols (cloud services). The institution shall still comply with the general requirements relating to a proper business organisation pursuant to section 25a (1) of the Banking Act in the case of other external procurement of IT services (see AT 9 number 1 – Explanations – of MaRisk). For each software procurement, the associated risks shall be appropriately assessed (see AT 7.2 number 4 sentence 2 of MaRisk).	Functional	Intersects With	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	5	
9.2	Outsourcing and other external procurement of IT services	Given the fundamental importance of IT to the institution, a risk assessment shall also be performed prior to each instance of other external procurement of IT services.	Functional	Intersects With	Third-Party Services	TPM-04	Mechanisms exist to mitigate the risks associated with third-party access to the organization's Technology Assets, Applications, Services and/or Data (TAASD).	5	
9.2	Outsourcing and other external procurement of IT services	Given the fundamental importance of IT to the institution, a risk assessment shall also be performed prior to each instance of other external procurement of IT services.	Functional	Intersects With	Third-Party Risk Assessments & Approvals	TPM-04.1	Mechanisms exist to conduct a risk assessment prior to the acquisition or outsourcing of technology-related Technology Assets, Applications and/or Services (TAAS).	8	
9.3	Outsourcing and other external procurement of IT services	Other external procurement of IT services shall be managed in line with the strategies, taking account of the institution's risk assessment. The rendering of the service owed by the service provider shall be monitored in line with the risk assessment.	Functional	Intersects With	Acquisition Strategies, Tools & Methods	TPM-03.1	Mechanisms exist to utilize tailored acquisition strategies, contract tools and procurement methods for the purchase of unique Technology Assets, Applications and/or Services (TAAS).	3	
9.3	Outsourcing and other external procurement of IT services	Other external procurement of IT services shall be managed in line with the strategies, taking account of the institution's risk assessment. The rendering of the service owed by the service provider shall be monitored in line with the risk assessment.	Functional	Intersects With	Review of Third-Party Services	TPM-08	Mechanisms exist to monitor, regularly review and assess External Service Providers (ESPs) for compliance with established contractual requirements for security, compliance and resilience controls.	5	
9.4	Outsourcing and other external procurement of IT services	The contractual arrangements shall take appropriate account of the measures derived from the risk assessment relating to other external procurement of IT services. Appropriate account shall be taken of the results of the risk assessment in the operational risk management process, primarily in the overall risk assessment for operational risk.	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	8	
9.4	Outsourcing and other external procurement of IT services	The contractual arrangements shall take appropriate account of the measures derived from the risk assessment relating to other external procurement of IT services. Appropriate account shall be taken of the results of the risk assessment in the operational risk management process, primarily in the overall risk assessment for operational risk.	Functional	Intersects With	Contract Flow-Down Requirements	TPM-05.2	Mechanisms exist to ensure applicable security, compliance and resilience requirements are included in contracts that flow-down to applicable sub-contractors and suppliers.	8	
9.5	Outsourcing and other external procurement of IT services	The risk assessments relating to other external procurement of IT services shall be reviewed and amended regularly and on an ad hoc basis, together with the contractual details, where appropriate.	Functional	Intersects With	Third-Party Risk Assessments & Approvals	TPM-04.1	Mechanisms exist to conduct a risk assessment prior to the acquisition or outsourcing of technology-related Technology Assets, Applications and/or Services (TAAS).	5	
10	IT service continuity management	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
10.1	IT service continuity management	The institution shall define business continuity management objectives and establish a business continuity management process on this basis. Arrangements shall be made for emergency situations in time-critical activities and processes (contingency plan). The measures defined in the contingency plan shall be suitable for reducing the extent of potential losses (see AT 7.3 number 1 of MaRisk). The contingency plan shall include business continuity and recovery plans. In the event of outsourcing of time-critical activities and processes, the outsourcing institution and the outsourcing provider shall have coordinated contingency plans (see AT 7.3 number 2 of MaRisk). The effectiveness and appropriateness of the contingency plan shall be reviewed regularly. For time-critical activities and processes, it shall be demonstrated at least once a year and on an event-driven basis for all relevant scenarios (see AT 7.3 number 3 of MaRisk).	Functional	Intersects With	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR) playbooks).	8	
10.2	IT service continuity management	The objectives and overall conditions of IT service continuity management shall be defined on the basis of the business continuity management objectives.	Functional	Intersects With	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR) playbooks).	8	
10.3	IT service continuity management	On the basis of the contingency plan, the institution shall prepare IT contingency plans for IT systems that support time-critical activities and processes.	Functional	Intersects With	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR) playbooks).	8	
10.4	IT service continuity management	The effectiveness of the IT contingency plans shall be verified by IT contingency tests performed at least once a year. The tests shall cover all IT systems that support time-critical activities and processes. Dependencies between IT systems or of jointly used IT systems shall be adequately taken into account. An IT testing concept shall be prepared for this purpose.	Functional	Intersects With	Contingency Plan Testing & Exercises	BCD-04	Mechanisms exist to conduct tests and/or exercises to evaluate the contingency plan's effectiveness and the organization's readiness to execute the plan.	8	
10.5	IT service continuity management	The institution is required to demonstrate that, if a data centre fails, the time-critical activities and processes can be provided from a sufficiently remote data centre and for an adequate time, as well as for the subsequent restoration of normal IT operation.	Functional	Intersects With	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR) playbooks).	8	
10.5	IT service continuity management	The institution is required to demonstrate that, if a data centre fails, the time-critical activities and processes can be provided from a sufficiently remote data centre and for an adequate time, as well as for the subsequent restoration of normal IT operation.	Functional	Intersects With	Contingency Plan Testing & Exercises	BCD-04	Mechanisms exist to conduct tests and/or exercises to evaluate the contingency plan's effectiveness and the organization's readiness to execute the plan.	8	
10.5	IT service continuity management	The institution is required to demonstrate that, if a data centre fails, the time-critical activities and processes can be provided from a sufficiently remote data centre and for an adequate time, as well as for the subsequent restoration of normal IT operation.	Functional	Intersects With	Alternate Storage Site	BCD-08	Mechanisms exist to establish an alternate storage site that includes both the assets and necessary agreements to permit the storage and recovery of system backup information.	8	
10.5	IT service continuity management	The institution is required to demonstrate that, if a data centre fails, the time-critical activities and processes can be provided from a sufficiently remote data centre and for an adequate time, as well as for the subsequent restoration of normal IT operation.	Functional	Intersects With	Alternate Processing Site	BCD-09	Mechanisms exist to establish an alternate processing site that provides security measures equivalent to that of the primary site.	8	
11	Managing relationships with payment service users	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
11.1	Managing relationships with payment service users	The risk mitigation measures required by section 53 of the ZAG to manage operational and security-related risks also contain measures with which the payment service users are addressed directly for risk reduction, in particular of the risk of fraud. This requires the establishment of appropriate management of the relationships with the payment service users.	Functional	Intersects With	Service Delivery (Business Process Support)	OPS-03	Mechanisms exist to define supporting business processes and implement appropriate governance and service management to ensure appropriate planning, delivery and support of the organization's technology capabilities supporting business functions, workforce, and/or customers based on industry-recognized standards to achieve the specific goals of the process area.	3	
11.1	Managing relationships with payment service users	The risk mitigation measures required by section 53 of the ZAG to manage operational and security-related risks also contain measures with which the payment service users are addressed directly for risk reduction, in particular of the risk of fraud. This requires the establishment of appropriate management of the relationships with the payment service users.	Functional	Intersects With	Risk Remediation	RSK-06	Mechanisms exist to remediate risks to an acceptable level.	8	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
11.2	Managing relationships with payment service users	The institution shall establish and implement processes through which the awareness of the payment service users for security-related risks relating to the payment services will be improved by supporting and advising the payment service users.	Functional	Intersects With	Service Delivery (Business Process Support)	OPS-03	Mechanisms exist to define supporting business processes and implement appropriate governance and service management to ensure appropriate planning, delivery and support of the organization's technology capabilities supporting business functions, workforce, and/or customers based on industry-recognized standards to achieve the specific goals of the process area.	3	
11.3	Managing relationships with payment service users	The support and advice offered to the payment service users shall be kept up-to-date and adapted to new risk situations. Amendments shall be communicated to the payment service user in an appropriate format.	Functional	Intersects With	Service Delivery (Business Process Support)	OPS-03	Mechanisms exist to define supporting business processes and implement appropriate governance and service management to ensure appropriate planning, delivery and support of the organization's technology capabilities supporting business functions, workforce, and/or customers based on industry-recognized standards to achieve the specific goals of the process area.	3	
11.4	Managing relationships with payment service users	If permitted by the product functionality, the institution shall offer payment service users an option to deactivate individual payment functions available to them.	Functional	Intersects With	Service Delivery (Business Process Support)	OPS-03	Mechanisms exist to define supporting business processes and implement appropriate governance and service management to ensure appropriate planning, delivery and support of the organization's technology capabilities supporting business functions, workforce, and/or customers based on industry-recognized standards to achieve the specific goals of the process area.	3	
11.5	Managing relationships with payment service users	If the payment service user has agreed upper limits, the payment service user shall be given an option to adapt the agreed limits.	Functional	Intersects With	Service Delivery (Business Process Support)	OPS-03	Mechanisms exist to define supporting business processes and implement appropriate governance and service management to ensure appropriate planning, delivery and support of the organization's technology capabilities supporting business functions, workforce, and/or customers based on industry-recognized standards to achieve the specific goals of the process area.	3	
11.6	Managing relationships with payment service users	To identify fraudulent or unauthorised use of the payment service user's payment accounts, the institution shall give the payment service user the option to receive alerts about successful and failed transactions.	Functional	Intersects With	Service Delivery (Business Process Support)	OPS-03	Mechanisms exist to define supporting business processes and implement appropriate governance and service management to ensure appropriate planning, delivery and support of the organization's technology capabilities supporting business functions, workforce, and/or customers based on industry-recognized standards to achieve the specific goals of the process area.	3	
11.7	Managing relationships with payment service users	The institution shall inform the payment service user promptly about updates to security procedures that could impact the payment service user in the context of providing payment services.	Functional	Intersects With	Service Delivery (Business Process Support)	OPS-03	Mechanisms exist to define supporting business processes and implement appropriate governance and service management to ensure appropriate planning, delivery and support of the organization's technology capabilities supporting business functions, workforce, and/or customers based on industry-recognized standards to achieve the specific goals of the process area.	3	
11.8	Managing relationships with payment service users	The institution shall support the payment service users in relation to all questions, support requests, alerts or irregularities or all security-related questions with regard to the payment services. The payment service users shall be informed appropriately how they can receive this support.	Functional	Intersects With	Service Delivery (Business Process Support)	OPS-03	Mechanisms exist to define supporting business processes and implement appropriate governance and service management to ensure appropriate planning, delivery and support of the organization's technology capabilities supporting business functions, workforce, and/or customers based on industry-recognized standards to achieve the specific goals of the process area.	3	
12	Critical infrastructure	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
12.1	Critical infrastructure	Against the backdrop of the other chapters of the BAIT and the other relevant supervisory requirements for financial institutions concerned with ensuring that appropriate precautions are taken to guarantee the availability, integrity, authenticity and confidentiality of information processing, this chapter is directed specifically at operators of critical infrastructure (CI operators). It adds requirements for the effective implementation of special measures to achieve the critical infrastructure protection (CIP) objective to the Supervisory Requirements for IT in Financial Institutions. The CIP objective shall be understood here as maintaining the society's security of supply for the critical services named in section 7 of the BSI-KritisV (cash supply, card-based payment transactions, conventional payment transactions and the clearing and settlement of securities and derivatives transactions), because the failure or impairment of these services could lead to serious supply disruptions or threats to the public security. The CI operators concerned (and, where services are outsourced, their IT service providers too) shall describe and effectively implement appropriate measures for critical services to reduce the risks to the secure operation of critical infrastructure to a level appropriate for the CIP objective. To do this, CI operators and their IT service providers shall align themselves with the relevant standards and consider high availability concepts. Thereby state of the art technology shall be adhered to. Companies may choose to use this chapter to provide verification under section 8a (3) of the Act on the Federal Office for Information Security (Gesetz über das Bundesamt für Sicherheit in der Informationstechnik – BSI Act) within the context of an audit of the annual financial statements. This requires that all information technology systems, components and processes that are part of the critical infrastructure are covered by the audit in full. Alternatively, CI operators can adopt a company-specific approach or	Functional	No Relationship	N/A	N/A	N/A	0	
12.2	Critical infrastructure	The extent of critical infrastructure within the information domain shall be clearly tagged. Thereby all relevant interfaces should be included. All relevant BAIT requirements and other supervisory requirements shall be applied to all components and areas of the critical service in a clear and comprehensible manner. Critical services shall be monitored appropriately. The potential impact that security incidents could also have on critical services shall be assessed.	Functional	No Relationship	N/A	N/A	N/A	0	
12.3	Critical infrastructure	The information risk management and information security management under chapters 3 and 4 of the BAIT shall take the CIP objective into account and adopt measures to ensure that it is achieved. In particular, risks that have the potential to impair critical services to a significant degree shall be reduced using appropriate measures for risk mitigation and risk avoidance to a level appropriate for the CIP objective. Measures which are able to counter the risks to availability when the need for protection is high or very high are particularly suitable for this. Among other things, high availability concepts should therefore be examined and, if appropriate, applied.	Functional	No Relationship	N/A	N/A	N/A	0	
12.4	Critical infrastructure	The CIP objective shall always be taken into account, from when the protection requirements are determined, during the definition of appropriate measures and through to the effective implementation of these measures, including the implementation and regular testing of relevant emergency preparedness measures.	Functional	No Relationship	N/A	N/A	N/A	0	
12.5	Critical infrastructure	The verification under section 8a (3) of the BSI Act regarding compliance with the requirements under section 8a (1) of the BSI Act can be conducted as part of the audit of the annual financial statements. CI operators are to submit the relevant verification documents to the BSI on time, in accordance with the relevant requirements of the BSI.	Functional	No Relationship	N/A	N/A	N/A	0	